



Enhancing Continuity of Care Through Unified Electronic Health Records: A System for Unifying Patient Medical Data Across Healthcare Institutions

Project name: Sijill / سجل

Graduation project by:

- *Mostafa Mahmoud Khedr*
- *Mostafa Mohammad Reda*
- *Mahmoud Emad Sallam*
- *Mounir Osama Shebl*
- *Mohammad Ayman Mosa*
- *Mohammad Ebrahim Hassan*
- *Mohammad Hamed Ghaly*

Under supervision of:

Dr. Sara Shehab

Dr. Asmaa Saad

Graduation Project Committee Members

Committee Supervisor: Dr. Sara Shehab

Signature: _____

Date: _____

Committee Co-Supervisor: Dr. Asmaa Saad

Signature: _____

Date: _____

Committee First Member:

Signature: _____

Date: _____

Committee Second Member:

Signature: _____

Date: _____

Committee Third Member:

Signature: _____

Date: _____

Abstract

In the modern healthcare landscape, the fragmentation of medical data remains a critical challenge, often leading to diagnostic errors, redundant testing, and inefficient patient care. Traditionally, patient records are siloed within individual institutions, preventing healthcare providers from accessing a comprehensive medical history.

This documentation outlines the development and implementation of Sijill, a unified Electronic Health Record (**EHR**) system designed to eliminate these information gaps by creating a portable, centralized, and continuously updated medical history for every patient. Sijill functions as an interoperable integration layer that seamlessly connects the key pillars of the healthcare ecosystem: patients, healthcare providers, laboratories, imaging centers, and research departments.

The system utilizes a cross-platform mobile application to empower patients with full ownership of their data, granting them the ability to manage access permissions to healthcare providers and view their complete medical timeline. Simultaneously, web-based portals allow verified healthcare providers to document clinical encounters using international standards such as **ICD-11** and **SNOMED CT**, while dedicated interfaces for laboratories and imaging centers facilitate the secure upload of test and imaging results that get attached to patient's profile.

Furthermore, Sijill aligns with the goals of **Egypt's 2030 Vision**, striving to modernize healthcare data management, reduce medical errors, and foster a data-driven medical environment.

Acknowledgements

We would like to express our deepest gratitude to everyone who contributed to the successful completion of Sijill.

Their guidance, technical support, and encouragement were essential in bringing this vision to life.

First and foremost, we would like to extend our sincere appreciation to our esteemed supervisors ***Dr. Sara Shehab & Dr. Asmaa Saad***.

Their expert mentorship, insightful feedback, and continuous academic support throughout the research and development phases were vital in shaping the quality and direction of this work.

We are also profoundly grateful to ***Dr. Mahmoud Eid***, Director of the **University Medical Administration**. His cooperation and practical insights into the healthcare system provided us with an invaluable perspective on the real-world challenges of medical data management, ensuring that Sijill remains a solution grounded in actual clinical needs.

Finally, a special thanks goes to the members of the Development Team (***OverEngineered***).

This project is a result of our collective hard work, long hours of coding, and persistent problem-solving. The spirit of collaboration and shared commitment to excellence made this journey both productive and rewarding.

Governance and Institutional Context

The Sijill system, as conceptualized in this document, is designed explicitly as **national critical infrastructure for electronic health records rather than a commercial venture**. Its implementation, operation, and data stewardship are intended to fall exclusively under the authority and ownership of a governmental body, such as the Ministry of Health and Population.

Governmental Ownership and Stewardship

- The Sijill platform, all associated software, and the aggregated health data within it shall be the property of the state.
- The government, acting through a designated authority, shall be the sole data controller and steward. This centralizes accountability and ensures that data is managed in the public interest, not for commercial gain.

This Software System is a purely academic deliverable. It represents a conceptual design and technical proposal for a graduation project at the Faculty of Computer Science & Artificial Intelligence. The authors, contributors, and affiliated academic institutions explicitly state and warrant the following:

1. No Production Intent: The project team, "*OverEngineered*", has no intention, plan, or capability to deploy, or operate the Sijill system in any live, production, or public environment. This project is strictly confined to an academic demonstration and proof-of-concept within a controlled, non-production setting.
2. Conditional on Governmental Authorization: Any potential future realization of a system based on this concept is expressly and unconditionally contingent upon direct initiation, full funding, explicit written authorization, and complete operational control by the competent Egyptian governmental authorities, specifically the Ministry of Health and Population. Without such formal state sanction, this concept will not proceed beyond its academic prototype phase.
3. No Data Responsibility: The team assumes zero liability or responsibility for the collection, storage, or processing of any real citizen medical data. Any testing during the academic project will be fully anonymized, synthetic, or mock data that does not pertain to real individuals.

In summary, this document should in no way be construed as a plan for an independent software product or service. It is an academic exercise outlining a potential solution that, by its very nature, can only be legitimately realized by and under the sovereign control of the Egyptian state.

Table of Content

1. Introduction.....	8
1.1 Background and Overview.....	8
1.2 Motivation.....	10
1.3 Problem Statement.....	12
1.4 Project Objective.....	14
1.5 Contribution to the medical field.....	17
1.6 Project Outline.....	20
2. Literature Review.....	22
2.1 Introduction: The digital transformation of healthcare records.....	22
2.2 Foundational Concepts and the Evolution of EHR Systems.....	22
2.3 Analysis of Existing and Related Systems.....	23
2.3.1 National and Regional Health Information Exchanges (HIEs).....	23
2.3.2 Patient-Centric and Personal Health Record (PHR) Platforms.....	24
2.3.3 Research Prototypes and Academic Projects.....	25
2.3.4 Synthesis: Sijill's Distinctive Position.....	25
3. Requirements & System Analysis.....	26
3.1 Functional Requirements.....	26
3.1.1 Unified User Registration and Verification Workflow.....	26
3.1.2 Role-Based Access Control and Authorization Management.....	26
3.1.3 Multi-Factor Authentication and Token-Based Security.....	27
3.1.4 Centralized Admission Control, Rate Limiting and Traffic Protection.....	27
3.1.5 Database-Level Cryptographic Protection.....	28
3.1.6 Patient Medical Identity.....	28
3.1.7 Patient Health Journal and Recovery Self-Tracking.....	29
3.1.8 Patient Medical History.....	30
3.1.9 Clinical Encounters and Authorized Care Provision.....	31
3.1.10 Automated Medical Notifications and Patient Reminders.....	31
3.1.11 Laboratory Test Ordering and Result Integration.....	32
3.1.12 Medical Imaging Requests and Result Association.....	32
3.1.13 Administrative Verification and Account Governance.....	33
3.1.14 Audit Log Review and User Suspension Management.....	33
3.1.15 User Reports and Support Request Management.....	34
3.2 Non-Functional Requirements.....	34
3.2.1 Security and Privacy.....	34
3.2.2 Performance and Scalability.....	35
3.2.3 Availability and Reliability.....	35
3.2.4 Maintainability and Extensibility.....	35
3.2.5 Usability and Accessibility.....	36
3.2.6 Auditability and Compliance Readiness.....	36
3.2.7 Data Integrity and Consistency.....	36
3.3 System Models.....	37
3.3.1 Entity Relationship Diagram.....	37
3.3.2 Data Flow Diagram.....	37
3.3.3 Use Case Diagram.....	37
3.3.4 Database Schema.....	37
3.4 Target Audience & Visual Identity.....	38

4. Methodology.....	40
4.1 System Design.....	40
4.1.1 System Architecture.....	40
4.1.2 Technology Stack.....	42
4.1.3 Design Patterns.....	43
4.1.4 UI/UX Design.....	44
4.2 Implementation.....	46
4.2.1 Development & Environment Tools.....	46
4.2.2 Back-End Implementation.....	47
4.2.3 Frontend Implementation.....	48
4.2.4 Testing Approaches.....	49
4.3 Results & Evaluation.....	50
5. Conclusion & Future Work.....	51
6. References & Appendices.....	52
6.1 References.....	52
Appendices.....	54

1. Introduction

1.1 Background and Overview

Electronic Health Records (EHRs) represent a fundamental shift in healthcare delivery, moving from paper-based, fragmented records to digital, integrated systems that can be accessed and shared across healthcare settings. The primary goal of an EHR is to create a longitudinal, patient-centric record that includes demographics, medical history, medications, immunization status, laboratory test results, radiology images, and vital signs, among other clinical data. By consolidating this information into a single, accessible source, EHRs aim to improve the quality, safety, and efficiency of patient care. Studies have shown that EHR implementation can lead to significant reductions in medication errors, improvements in preventive care and chronic disease management, and enhanced coordination among multiple healthcare providers. The transition to digital records is considered a cornerstone of modern healthcare systems worldwide, facilitating better clinical decision-making and forming the basis for advanced data analytics and population health management [1].

The global push for digital health transformation is often driven by national strategies aimed at improving healthcare outcomes and efficiency. For instance, many countries have established digital health blueprints, such as the **NHS Long Term Plan** in the United Kingdom, which emphasizes integrated care records, or the **21st Century Cures Act** in the United States, which focuses on interoperability and patient data access. These initiatives recognize that fragmented health information, where data is siloed within individual hospitals, clinics, or laboratories which leads to inefficiencies, duplicated tests, and potentially harmful clinical decisions made without a complete patient history. A unified EHR system addresses this fragmentation by creating a single source of truth for a patient's health journey, accessible to authorized providers regardless of where care was delivered [2].

In Egypt, the healthcare sector is undergoing a significant transformation aligned with the Egypt Vision 2030 and the Presidential Initiative "100 Million Healthy Lives," which underscores the importance of healthcare as a pillar of sustainable development. A critical component of this transformation is the modernization of health information systems to create an integrated, efficient, and data-driven healthcare ecosystem. Currently, patient health information in Egypt is often dispersed across various public and private healthcare facilities, leading to challenges in continuity of care, especially for patients with chronic conditions or those who require care from multiple specialists. The lack of a centralized, interoperable system can result in delayed diagnoses, unnecessary repeat testing, and increased costs for both patients and the healthcare system.

Therefore, developing a national, unified EHR platform is not just a technological upgrade but a strategic imperative to enhance public health outcomes, support clinical research, and optimize resource allocation [3].

The **Sijill** project is conceived as a direct response to this national need. It is designed to be a comprehensive, unified EHR system that serves as a portable and continuously updated digital health profile for every citizen. The name "Sijill" (سجل), meaning "record" or "register" in Arabic, reflects its core function as the authoritative repository of an individual's lifelong health information. Unlike traditional hospital information systems (HIS) or standalone clinic records, Sijill aims to operate as an integration layer at a national or institutional level, aggregating standardized data from disparate sources, including hospitals, primary care centers, diagnostic laboratories, and imaging facilities. This approach ensures that a patient's complete medical history is available at the point of care, whether during a routine doctor's visit, a specialist consultation, or a medical emergency.

The vision for Sijill extends beyond mere record-keeping. It is envisioned as an enabling platform for a more proactive and preventive healthcare model. By providing healthcare providers with a holistic view of the patient, it supports more accurate diagnoses and personalized treatment plans. For patients, it promises greater empowerment and engagement in their own health through direct access to their records and tools for managing appointments and medications. For health system administrators and policymakers, the aggregated, anonymized data within Sijill offers unprecedented insights into disease patterns, treatment effectiveness, and public health trends, enabling evidence-based planning and resource management. Furthermore, in emergency situations, Sijill's proposed quick-access mechanism via a scannable QR code could provide first responders with immediate access to life-saving information such as blood type, allergies, and active conditions, potentially improving emergency outcomes.

In summary, the development of Sijill is situated at the intersection of technological innovation and national healthcare strategy. It seeks to leverage modern software architecture, robust security protocols, and interoperability standards to build a system that addresses the critical challenge of health information fragmentation. This graduation project report documents the comprehensive analysis, design, and proposed implementation of the Sijill system, detailing its functional capabilities, architectural decisions, and its potential impact on the healthcare landscape in Egypt.

1.2 Motivation

The motivation for developing the **Sijill** system stems from a confluence of critical challenges in modern healthcare delivery and the transformative potential of digital technology to address them. The driving forces are not merely technical but are fundamentally rooted in improving patient outcomes, clinical workflows, and public health efficacy.

1. Fragmentation of Health Information: A primary motivator is the pervasive issue of fragmented and siloed patient data. In current healthcare ecosystems, patient information is often trapped within individual institutions: hospitals, clinics, diagnostic labs, and pharmacies, each maintaining its own isolated records. This fragmentation forces healthcare providers to make decisions with an incomplete clinical picture, leading to redundant tests, medication errors, and delayed diagnoses. For patients, especially those with chronic conditions requiring care from multiple specialists, this can result in a disjointed and inefficient care experience. Sijill is motivated by the urgent need to create a **longitudinal, patient-centric record** that bridges these silos, ensuring that every authorized provider has access to a complete and unified health history at the point of care [4]

2. Enhancing Patient Safety and Care Quality: Medical errors remain a significant cause of patient harm globally. Studies estimate that medical errors are the third leading cause of death in some developed countries, with many errors linked to poor information transfer and communication. A unified EHR like Sijill can directly mitigate such risks. By providing instant access to a patient's full medication history, known allergies, previous diagnoses, and lab results, the system empowers clinicians to make safer prescribing and treatment decisions. Furthermore, integrated clinical decision support tools, though not explicitly detailed in the initial phase, are a logical future extension motivated by the goal of embedding evidence-based guidelines directly into the clinical workflow to reduce variability and improve adherence to best practices [5]

3. Empowering Patients and Promoting Engagement: Modern healthcare paradigms emphasize the role of the patient as an active participant in their own care. However, patients often lack easy access to their own medical information, hindering their ability to manage chronic conditions, prepare for visits, or share information with new providers. Sijill is motivated by the principle of **patient empowerment**. By providing a secure patient portal with access to medical records, medication reminders, and the ability to control data sharing via One-Time Passwords (OTPs), the system shifts control towards the patient. This aligns with global movements for "patient-generated health data" and "patient portals," which have been shown to improve patient satisfaction, adherence to treatment plans, and self-management of health.

4. Enabling Data-Driven Public Health and Research: From a macro perspective, aggregated and anonymized population health data is an invaluable asset for public health planning and medical research. Disparate data systems make it difficult to track disease outbreaks, understand treatment effectiveness across populations, or conduct large-scale epidemiological studies. Sijill is motivated by the potential to create a **national health data resource**. By standardizing data collection (using codes like ICD-11 and SNOMED CT) across all connected entities, the system can generate real-world evidence on disease prevalence, health outcomes, and resource utilization. This can inform national health policy, prioritize research funding, and ultimately lead to more effective and equitable healthcare services [6][7].

5. Supporting National Digital Health Agendas: The development of Sijill is directly aligned with strategic national initiatives. Egypt's Vision 2030 Sustainable Development Strategy identifies health as a key pillar and emphasizes the role of technology in building a comprehensive and innovative healthcare system. Furthermore, global institutions like the World Health Organization (WHO) advocate for the development of digital health infrastructures, including EHRs, as essential for achieving Universal Health Coverage (UHC). Implementing Sijill serves as a tangible step towards fulfilling these strategic commitments, positioning the national healthcare system to be more resilient, efficient, and capable of meeting future challenges [3]

6. Technological Feasibility and Innovation: The current maturity of key technologies makes the vision of Sijill technically feasible. The widespread adoption of cloud computing, robust mobile platforms (Android/iOS), advanced encryption standards, and interoperability protocols like RESTful APIs and DICOM provides a strong foundation. The motivation is to leverage these technologies not for their own sake, but to architect a system that is secure, scalable, and user-friendly. The project seeks to innovate specifically in the **privacy-centric access model** (using time-bound, patient-granted OTPs for full record access) and the **outcome tracking mechanism** (automated follow-ups for active diagnoses), addressing specific gaps in both functionality and patient-clinician collaboration.

In conclusion, the motivation for Sijill is multidimensional. It is a response to critical operational flaws in current health information management, a tool for enhancing clinical quality and patient safety, a platform for citizen empowerment, a resource for public health intelligence, and a strategic asset for national development. It is envisioned not just as a software application, but as foundational infrastructure for a more connected, intelligent, and patient-focused healthcare future for Egypt.

1.3 Problem Statement

The Egyptian healthcare system, while making significant strides, faces a critical infrastructural challenge: the absence of a **unified, interoperable Electronic Health Record (EHR) system**. This deficiency creates a cascade of problems that affect patients, healthcare providers, and the healthcare system as a whole. The Sijill project is designed to address the following core problems:

The Siloed Patient Data Dilemma: Currently, a patient's medical history is fragmented across multiple, disconnected repositories. A record from a public hospital is not accessible to a private clinic, lab results from one diagnostic center are not integrated with a specialist's notes from another facility, and emergency medical teams often have zero information about a patient's critical history. This data isolation forces a "reactive" model of care, where each clinical encounter starts from scratch. Physicians must rely on often-incomplete patient recollection, leading to an increased risk of **medical errors, duplicate testing, and ineffective treatment plans**. For patients with chronic conditions like diabetes or hypertension, this fragmentation severely hampers continuous care management and complicates the work of care coordinators [4].

Inefficiency in Clinical Workflows and Resource Utilization: The lack of data portability creates significant administrative burdens and operational inefficiencies. Healthcare providers spend excessive time requesting records from other facilities, waiting for faxes or CDs of images, and manually transcribing information. This **administrative overhead** reduces the time available for direct patient care and contributes to clinician burnout. From a system-wide perspective, the inability to share data leads to **unnecessary repetition of expensive diagnostic tests** (like MRI or CT scans), placing a financial burden on both patients and the healthcare system and exposing patients to redundant procedures.

The Patient as an Information Courier: In the absence of a connected system, the responsibility for integrating care falls on the patient. They are expected to remember and verbally relay their complete medical history, medication lists, and allergy information to every new provider. This model is inherently flawed. Patients may forget critical details, misunderstand medical terminology, or be physically unable to communicate in an emergency. This problem is exacerbated in situations requiring **continuity of care**, such as referrals between primary care physicians and specialists, or during transitions from hospital to home care [8].

Barriers to Patient Empowerment and Engagement: Informed patient participation is a pillar of modern healthcare. However, patients currently have limited to no access to their own consolidated health records. They can't easily review their lab trends, track their progress, or prepare questions for their doctors. This lack of access creates a **power and information asymmetry** between the provider and the patient, which can hinder shared decision-making and reduce adherence to treatment plans. Furthermore, patients have no streamlined, secure mechanism to grant temporary access to their records when seeking a second opinion or visiting other providers [9]

Hindered Public Health Surveillance and Medical Research: Public health initiatives and clinical research rely on comprehensive, population-level data to identify trends, evaluate interventions, and allocate resources. The current fragmented landscape makes it extraordinarily difficult to conduct **real-time disease surveillance** (as starkly demonstrated during the COVID-19 pandemic), track the epidemiology of non-communicable diseases, or assess the long-term outcomes of treatments across different demographics. Research projects are slowed by the need to manually aggregate data from disparate sources, which is often inconsistent in format and quality [10].

The Emergency Information Gap: In emergency medical situations, seconds count. Paramedics and emergency department staff routinely treat patients with no knowledge of their medical background. Critical information such as **blood type, drug allergies, current medications (especially anticoagulants), and implanted devices** is unknown. This gap forces emergency personnel to proceed cautiously, potentially delaying life-saving interventions or administering contraindicated treatments.

Security and Privacy in a Fragmented Environment: Ironically, while paper records or isolated digital systems are perceived as "safe," they often lack robust, standardized security and audit controls. Unauthorized physical access, lack of encryption, and no immutable access logs are common vulnerabilities. A centralized system like Sijill presents an opportunity to implement a **higher, consistent standard of security**, including role-based access control, end-to-end encryption, comprehensive audit trails, and patient-managed consent, addressing privacy concerns in a more systematic way than is possible with dozens of independent, potentially less secure systems [11].

In summary, the core problem is **health information disconnection**. This disconnection manifests as clinical risk, operational waste, patient disempowerment, and impaired public health capability. The Sijill project posits that a carefully designed, secure, and patient-centric unified EHR platform is the necessary infrastructure to reconnect this information, thereby transforming these systemic weaknesses into strengths for a more effective, efficient, and equitable healthcare system.

1.4 Project Objective

The Sijill project is guided by a set of clear, measurable, and ambitious objectives designed to directly address the problems outlined in the previous section. These objectives span technical, clinical, and strategic domains, aiming not just to build software, but to create a foundational platform for a transformed healthcare experience.

Primary Objective:

To design, prototype, and validate a secure, scalable, and interoperable **Unified Electronic Health Record (EHR) System** that creates a single, lifelong, and patient-centric digital health profile for individuals, thereby eliminating information silos across the healthcare ecosystem.

Specific Technical & Functional Objectives:

1. To Develop a Centralized and Standardized Health Data Repository:

- Design and implement a robust backend architecture capable of aggregating, standardizing, and securely storing heterogeneous health data from multiple sources (e.g., clinical encounters, lab results, imaging reports, patient notes).
- Enforce the use of international medical terminology standards (ICD-11 for diagnoses, SNOMED CT for clinical terms) to ensure data consistency, interoperability, and readiness for advanced analytics.

2. To Implement a Robust, Privacy-Centric Access Control Framework:

- Engineer a Role-Based Access Control (RBAC) system with granular permissions tailored to distinct user classes (Patients, Healthcare Providers, Labs, etc.).
- Implement a novel, patient-consent-driven access model where a healthcare provider's access to a patient's full medical history is temporary and conditional upon a patient-granted, time-limited One-Time Password (OTP), placing control firmly with the patient.
- Ensure all data access events are recorded in immutable audit logs for full transparency and accountability.

3. To Create an Intuitive Patient Empowerment Portal:

- Develop a cross-platform mobile application that provides patients with secure access to their unified medical records, including visit history, prescriptions, lab results, and imaging reports.
- Integrate features for patient-generated data (personal health notes) and automated reminders for medications and appointments set by providers.
- Implement a secure OTP generation mechanism, allowing patients to dynamically grant time-bound access to their records for specific providers or diagnostic centers.

4. To Design Efficient Clinical Workflow Tools for Healthcare Providers:

- Build a web-based portal that enables authorized Healthcare Providers (HCPs) to efficiently document clinical encounters using structured forms integrated with medical coding standards (ICD-11, SNOMED CT).
- Facilitate the creation of lab/imaging orders and prescriptions directly within an encounter, with automatic generation of corresponding pending tasks and reminders in the patient's portal.
- Provide HCPs with a dedicated view of their "patient panel", individuals they have previously treated, along with the associated encounter history, enabling continuity of care without requiring a new OTP for each visit.

5. To Establish Secure, Limited-Access Portals for Diagnostic Partners:

- Create specialized, upload-only web portals for Laboratories and Imaging Centers.
- Design a secure submission workflow where these entities can only upload results (structured data or files like PDFs/DICOM) using a valid, single-use OTP provided by the patient (linked either to a doctor's order or a self-request).
- Ensure these partners have no ability to browse, query, or view patient histories, enforcing the principle of least privilege and maximizing data privacy.

6. To Enhance Patient Safety and Clinical Decision-Making:

- By providing a complete health history at the point of care, the system aims to reduce medication errors (e.g., contraindicated prescriptions) and diagnostic delays.
- Introduce an Active Diagnosis & Outcome Tracking feature, where diagnoses are tracked until resolution (either marked by an HCP or via automated patient follow-up), promoting continuity and closure in care plans.

7. To Improve Healthcare System Efficiency:

- Significantly reduce the time providers spend searching for and collating patient information from disparate sources.
- Minimize the rate of duplicate diagnostic testing by making recent results immediately available to authorized providers.
- Streamline administrative processes for user onboarding and verification through structured registration workflows with document upload and admin approval.

8. To Lay the Foundation for Data-Driven Healthcare:

- Architect the system to support population-level analytics on aggregated, anonymized data.
- Create a dedicated Research Portal that allows authorized personnel to analyze trends in disease prevalence, treatment outcomes, and resource utilization, supporting public health strategy and medical research.

9. To Ensure High Standards of Security, Privacy, and Reliability:

- Implement end-to-end encryption for data in transit (HTTPS/TLS) and robust hashing for passwords.
- Design for high availability and scalability to handle a growing user base and data volume.
- Adhere to principles of privacy by design, ensuring patient data is protected by default and patient consent is a core operational mechanism.

10. To Produce a Comprehensive Academic Prototype and Documentation:

- Deliver a fully functional prototype demonstrating core workflows (patient registration, OTP-granted access, encounter documentation, result submission).
- Produce detailed technical documentation, including software architecture, API specifications, and a security model, serving as a blueprint for potential future development under governmental authority.

In essence, the objectives of the Sijill project transcend software development. They aim to prototype a new paradigm for health information management, one that is connected, intelligent, patient-controlled, and secure, ultimately contributing to the broader goal of a more effective and equitable healthcare system.

1.5 Contribution to the medical field

The Sijill project aims to make several distinct contributions to the domains of Health Informatics, Software Engineering, and Digital Public Health. While building upon existing research and systems, it proposes specific innovations in architecture, workflow, and patient-provider interaction that address recognized gaps in current EHR implementations, particularly within contexts similar to Egypt's. The contributions can be categorized as follows:

1. Contribution to Patient-Centric and Consent-Driven Access Models:

A well-documented challenge in health information exchange is balancing comprehensive data access with stringent privacy protection. Many systems rely on persistent access permissions for providers within the same organization or network. Sijill contributes a practical implementation of a dynamic, patient-mediated, and time-bound access model. By mandating that a patient generated OTP is required for a healthcare provider to view the full medical history (beyond a basic profile), the project operationalizes the principle of "patient as the gatekeeper" of their data. This goes beyond typical patient portal "view access" and creates a secure, auditable mechanism for sharing longitudinal records across institutional boundaries, a challenge highlighted in literature on cross-organizational Health Information Exchange (HIE). This model is a tangible step towards true patient-controlled health records.

2. Contribution to Secure Interoperability with External Diagnostic Entities:

Integrating diagnostic laboratories and imaging centers into an EHR ecosystem often poses security and workflow challenges. Sijill proposes a novel "upload-only" portal paradigm for these partners. By designing interfaces where Labs and Imaging Centers can only authenticate and submit results using a single-use OTP (linked to a specific order or patient request), the system enforces the principle of least privilege to an extreme degree. This architecture ensures these critical data contributors are integrated into the health information flow without being granted any ability to query or browse the patient database, significantly reducing the attack surface and privacy risk a contribution to secure system design for healthcare ecosystems involving third-party data producers.

3. Contribution to Continuity of Care through Active Diagnosis Tracking:

While EHRs are excellent at storing historical data, they are often less effective at promoting forward-looking care management. Sijill introduces a structured "Active Diagnoses" list with automated outcome tracking as a core feature. By automatically populating this list from clinical encounters and initiating automated, structured follow-up prompts to patients after a configurable period, the system shifts from a passive repository to an active participant in care continuity. This mechanized follow-up loop, which can resolve diagnoses based on patient-reported outcomes, is a contribution to closing the feedback loop in chronic disease management and post-acute care, an area identified as needing improvement in digital health tools.

4. Contribution to Architectural Patterns for Multi-Tenant Health Data:

The project's proposed backend architecture, utilizing a multi-tenant design with isolated tenant specific databases (e.g., for different hospitals or clinics) managed through a central control plane, offers a scalable blueprint for a national or regional EHR. This pattern, while used in enterprise software, is specifically adapted here for the high-stakes, high-regulation healthcare domain. The clear separation of tenant data enhances security, simplifies compliance, and allows for independent scaling a valuable architectural contribution for large-scale, federated health data platforms.

5. Contribution to Context-Specific Design for Emerging Digital Health Markets:

Much of the dominant EHR literature and design philosophy originates from Western healthcare contexts with established infrastructure and reimbursement models. Sijill's design consciously addresses challenges pertinent to emerging digital health markets, such as Egypt. This includes:

- **Hybrid Identity Verification:** Combining automated OCR/face-matching with a manual admin approval workflow to operate effectively in environments where fully digital, government-backed identity APIs may not be universally accessible.
- **QR-Code-Based Emergency Access:** Providing a low-tech, high-reliability solution for critical data access in emergency scenarios, which is functional even with basic smartphone cameras and intermittent connectivity.
- **Focus on Core Interoperability:** Prioritizing the seamless flow of information between primary care, specialist clinics, and diagnostic services, a key need in systems working to strengthen referral networks and integrated care.

By publishing its design rationale, challenges, and prototype outcomes, Sijill contributes a case study in building pragmatic, secure, and patient-focused health IT solutions in such contexts, which can inform similar initiatives in other regions.

6. Contribution to Academic and Pedagogical Knowledge:

As a comprehensive graduation project, Sijill serves as an applied research contribution. It demonstrates the integration of multiple advanced software engineering concepts, clean architecture, microservices patterns, reactive mobile development, and robust security protocols, into a single, coherent system designed for a critical real-world domain. The detailed requirements analysis, threat modeling, and adherence to healthcare standards (ICD-11, DICOM) provide a valuable educational resource and a template for future student projects in health informatics and secure software engineering. In summary, Sijill's contribution lies not in inventing wholly new technologies, but in their innovative synthesis and application to solve a specific set of interconnected problems. It proposes a concrete, architected vision for a unified EHR that is patient-empowering, privacy enhancing, workflow-efficient, and scalable, offering both practical design patterns and a conceptual framework that advances the discourse on next-generation health information systems.

1.6 Project Outline

This graduation project report is structured to provide a comprehensive narrative of the Sijill system's conception, design, and proposed implementation. The document is organized into distinct chapters, each focusing on a critical phase of the project lifecycle, from foundational research to future directions. The following outline details the content and logical flow of the subsequent chapters:

Chapter 2: Literature Review

This chapter will establish the theoretical and technical foundation for the project. It will begin with an exploration of Electronic Health Records (EHRs), their evolution, core benefits, and documented challenges, particularly regarding interoperability and user adoption. It will then delve into the critical domain of health data standards, examining the role and implementation of ICD11, SNOMED CT, and DICOM in enabling structured data exchange. A review of security and privacy frameworks in healthcare IT, including data protection regulations and technical mechanisms like encryption and access control, will be presented. Finally, the chapter will survey existing EHR systems and related research, analyzing their architectures, features, and limitations to identify gaps and inform Sijill's design decisions.

Chapter 3: Requirements and System Analysis

This chapter details the systematic approach taken to define the Sijill requirements. The core of the chapter will be the requirements engineering process, elaborating on how both functional and non-functional requirements were identified, prioritized, and specified, as partially codified in the SRS document. This includes discussions on stakeholder analysis, use case development, and the derivation of key system models such as Entity-Relationship Diagrams (ERD), Data Flow Diagrams (DFD), and Use Case Diagrams to visually represent the system's structure and behavior.

Chapter 4: Methodology

This chapter transitions from analysis to concrete design. It will first present the high-level system architecture, illustrating the main components (client applications, backend API, databases, file storage) and their interactions. The selection rationale for core technologies and frameworks (e.g., Node.js/NestJS for backend, Flutter for mobile, React for web, PostgreSQL) will be justified based on project requirements like scalability, performance, and developer ecosystem. The chapter will then detail critical design decisions, including the multi-tenant data isolation strategy, the security architecture encompassing authentication (JWT, OTP), authorization (RBAC), and encryption, and the API design following RESTful principles. Key database schema design and modular software architecture (adhering to Clean Architecture/SOLID principles) will also be explained. This chapter provides a detailed account of the system's construction. It will be organized by major subsystems:

- **Backend Service Implementation:** Description of core modules (user management, encounter service, order service), integration with medical terminology APIs, file handling logic (for PDFs, DICOM), and the implementation of business logic and data validation. Sijill – Unified Electronic Health Record System Page 13
- **Patient Mobile Application (Flutter):** Implementation of key features: authentication, medical record viewer, OTP generator, emergency card QR display, and notification handling.
- **Healthcare Provider Portal (React):** Development of the clinical encounter documentation interface, patient search/panel, and integration with ICD-11/SNOMED CT lookup services.
- **Administrative & Diagnostic Portals:** Build-out of the admin verification dashboard and the limited-functionality upload portals for Labs and Imaging Centers.
- **Integration and Deployment:** Discussion of cloud services used, containerization (Docker), CI/CD pipeline setup, and the configuration of the development/staging environment.

Chapter 5: Conclusion and Future Work

The final chapter summarizes the entire project. It will restate the problem, recap the solution provided by Sijill, and present the key conclusions drawn regarding the feasibility and impact of its design. The chapter will then propose a roadmap for future work, outlining potential enhancements such as:

- Advanced AI/ML integration for clinical decision support or predictive analytics.
- Expansion of interoperability through FHIR (Fast Healthcare Interoperability Resources) APIs.
- Enhanced patient engagement features like wearable device integration or telehealth modules.
- Robust performance, security, and penetration testing at scale.
- Piloting and user experience research in a clinical simulation environment.

Chapter 6: References and Appendices

The report is supplemented with references for all medical claims to support it. Also provides appendices containing supplementary material, such as detailed API documentation snippets, comprehensive database schema diagrams, sample user interface mockups, and a glossary of technical and medical terms.

2. Literature Review

2.1 Introduction: The digital transformation of healthcare records

The digitization of health information, moving from fragmented paper-based systems to integrated Electronic Health Record (EHR) systems, represents a paradigm shift in healthcare delivery comparable to the transformation seen in other sectors like finance and education. Globally, this shift is recognized as a cornerstone for improving patient safety, care coordination, and operational efficiency within health systems. However, the journey towards effective, interoperable, and user adopted EHRs is fraught with technical, organizational, and human-centric challenges. This chapter surveys the existing academic and practical landscape of EHR systems and related health information technologies. It examines foundational concepts, prevailing architectural models, critical challenges in security and interoperability, and emerging trends, with a particular focus on implementations relevant to national contexts and patient empowerment. The goal is to establish a rigorous foundation that contextualizes the Sijill project, identifies gaps in current solutions, and justifies its proposed innovative architecture [12].

2.2 Foundational Concepts and the Evolution of EHR Systems

The concept of an Electronic Health Record extends beyond a simple digital chart. A comprehensive EHR is defined as a longitudinal, patient-centric collection of health information generated across all care delivery settings. Its evolution can be traced from departmental systems (e.g., laboratory, radiology) in the 1980s to integrated hospital-wide systems, and more recently, to the vision of regional or national health information networks.

Early benefits documented in literature include improved legibility, centralized access within an institution, and basic clinical decision support, leading to reductions in certain medication errors. The current frontier, however, is interoperability, the ability of different information systems to exchange, interpret, and use shared data seamlessly. This is critical because the value of an EHR multiplies when it provides a complete health history, not just an institutional snapshot. The pursuit of interoperability has led to the development and adoption of international standards like **SNOMED CT** for clinical terminology and **ICD-11** for diagnoses, which are essential for semantic understanding across systems. Despite these standards, a persistent challenge, particularly in developing healthcare markets, is the existence of "**information silos**," where patient data remains trapped within proprietary systems of individual hospitals or clinic networks, leading to fragmented care and clinical risks [1].

2.3 Analysis of Existing and Related Systems

A critical component of this review is the analysis of specific Electronic Health Record (EHR) systems, Health Information Exchanges (HIEs), and related digital health platforms that share conceptual or architectural similarities with the proposed Sijill system. This analysis highlights the state of the art, identifies common pitfalls, and clarifies Sijill's unique position.

2.3.1 National and Regional Health Information Exchanges (HIEs)

- **The U.S. "Meaningful Use" Ecosystem & Regional HIEs:** Following the HITECH Act of 2009, the United States incentivized the creation of numerous regional HIEs (e.g., Indiana Health Information Exchange (IHIE), Surescripts, eHealth Exchange). These are federated networks where hospitals, labs, and clinics agree to share data, often using a record locator service to find patient data across members. While successful in proving large-scale data exchange is possible, evaluations have noted challenges: complex patient consent models that vary by state, sustainability dependent on participant fees, and fragmentation between different HIE networks themselves. This contrasts with Sijill's proposed unified, state-owned national model, which aims to avoid network-of-networks complexity by establishing a single, sovereign platform [13].

- **Estonia's "e-Health Record":** Often cited as a global benchmark, Estonia's nationwide EHR is a centralized repository accessible to patients and authorized providers. It is tightly integrated with the national digital ID (Smart ID), providing strong authentication. Its success is built on a small, digitally literate population and a pre-existing, comprehensive digital government infrastructure. The key lesson for Sijill is the critical role of a reliable national digital identity system for seamless and secure access, a dependency Sijill's hybrid (OCR + admin) registration workflow is designed to accommodate in its absence [14].

- **Saudi Arabia's "Nphies" (National Platform for Health and Insurance Exchange Services):** This is a highly relevant example from the region. Nphies acts as a government mandated central clearinghouse for electronic claims and referrals, aggregating data from both public and private sector providers. While focused initially on financial and administrative transactions, its evolution towards a comprehensive health information utility demonstrates the feasibility and impact of a top-down, regulatory-driven approach in a Gulf Cooperation Council (GCC) context. Sijill shares this governance philosophy but places a stronger primary emphasis on clinical care delivery and patient empowerment rather than claims processing [15].

2.3.2 Patient-Centric and Personal Health Record (PHR) Platforms

- **Apple Health Records:** This feature on iPhones allows users to aggregate health records from participating U.S. healthcare institutions using the **FHIR (Fast Healthcare Interoperability Resources)** standard. It is a classic example of a patient-managed aggregation model. The patient must initiate connections to each hospital, and data is stored locally on the device. While powerful for engaged patients in a FHIR-enabled ecosystem, it relies entirely on the willingness and technical capability of individual institutions to provide APIs. Sijill inverts this model: it is a proactive, provider-initiated system of record where data is pushed to a central profile by law/policy, reducing the burden of aggregation on the patient [16].
- **Open-Source EHR Platforms: OpenMRS & Bahmni:** **OpenMRS** is a widely adopted, community-driven open-source platform designed for resource-constrained environments, particularly in low- and middle-income countries for managing HIV/AIDS and tuberculosis programs. **Bahmni** is an integrated hospital information system built on OpenMRS for single facilities. These systems excel at flexibility and local adaptation. However, they are typically deployed as standalone instance for a single clinic or hospital group. Sijill's challenge and innovation lie not in replicating a single-instance EHR, but in architecting a secure, multi-tenant national platform that could potentially interconnect numerous such standalone systems in the future [17].
- **Commercial "Unified EHR" Vendors (e.g., Epic, Cerner):** Companies like Epic and Cerner dominate the hospital EHR market in many Western countries with their "unified" systems. However, their "unification" is often confined within a single healthcare enterprise (e.g., a hospital chain). Sharing data outside that enterprise, even with another Epic customer, can still require complex and expensive interfaces. Their model is fundamentally commercial and institution-centric, whereas Sijill is conceived as a public good, patient-centric national utility [18].

2.3.3 Research Prototypes and Academic Projects

The academic literature contains numerous prototypes exploring specific technical challenges relevant to Sijill:

- **Consent Management Systems:** Various research projects have proposed blockchain-based consent managers or advanced attribute-based encryption for granular health data sharing. While technologically sophisticated, these often remain as proofs-of-concept, facing hurdles in performance, usability, and integration with real-world clinical workflows. Sijill's OTP based access is a deliberate choice for pragmatic simplicity and audibility, favoring a model that is easily understandable by patients and enforceable in an audit trail [19].
- **Interoperability Middleware:** Projects have focused on creating middleware "adapters" to translate between legacy hospital data formats and modern standards like FHIR. Sijill's architecture, with its dedicated, limited portals for labs and imaging centers, can be seen as a strategic, targeted form of middleware, creating a standardized on-ramp for critical data types before tackling the more complex problem of full legacy hospital system integration [16].

2.3.4 Synthesis: Sijill's Distinctive Position

No single existing system embodies all the core principles of Sijill. National HIEs, such as Estonia's e-Health Record, provide centralized aggregation of patient data but often lack the deeply patient controlled, granular access and consent mechanisms that empower individuals to manage who sees what. Patient-centric tools like Apple Health Records give users direct control over their data, yet they operate in a fragmented, pull-based ecosystem and depend heavily on each institution's technical cooperation. Commercial EHR vendors such as Epic and Cerner offer powerful unified systems, but these remain proprietary, enterprise-centric, and largely siloed, limiting cross organizational interoperability. Open-source platforms like OpenMRS and Bahmni excel in adaptability and local customization, but are not architected for national-scale deployments.

Sijill proposes a novel synthesis of these approaches. It combines the mandatory, nationwide aggregation of a traditional HIE with dynamic, patient-granted consent inspired by advanced PHR research. Its architecture enforces strict data minimization for external partners through upload-only portals, ensuring both security and privacy, while still enabling seamless clinical use. By integrating these design principles into a cohesive national framework, Sijill addresses the gaps present in every other model: centralization without patient control, patient empowerment without comprehensiveness, commercial unification without openness, and local flexibility without scalability. Its contribution lies not only in the conceptual integration of these features but also in providing a concrete architectural blueprint tailored to a specific national context, demonstrating how patient-centric, secure, and interoperable healthcare data management can be realized in practice.

3. Requirements & System Analysis

3.1 Functional Requirements

3.1.1 Unified User Registration and Verification Workflow

Description:

The system provides a unified registration workflow for all user types, including patients, healthcare providers, laboratories, and imaging centers. Although these users differ in roles and privileges, their onboarding process follows a consistent and secure pattern. During registration, the user submits a structured form containing textual information along with required supporting documents. The system validates the submitted data for correctness, completeness, and format compliance, and securely stores all uploaded files. To verify ownership of the provided contact information, the system issues a One-Time Password (OTP) using one of the supported delivery mechanisms (email, SMS, or time-based authenticator). Only after successful OTP validation is the account created. Newly created accounts are not activated immediately. Instead, they are placed in a Pending Verification state, after which a verification request is forwarded to an authorized administrator. The administrator reviews the submitted information and documents and either approves or rejects the registration. Access to system features remains restricted until administrative approval is granted. This workflow ensures that all system users are uniquely identifiable, contact-verified, and institutionally approved before gaining access to sensitive healthcare data.

3.1.2 Role-Based Access Control and Authorization Management

Description:

The system enforces strict role-based access control (RBAC) to ensure that users can only access functionality and data explicitly permitted by their assigned role. Each user is associated with a predefined role (e.g., patient, healthcare provider, laboratory, imaging center, administrator), and all system permissions are derived exclusively from this role assignment. Based on the user's role, the system dynamically determines:

- **Accessible features and operations**
- **Authorized data scopes**
- **Available user interface components**

Preventing unauthorized actions even if client-side controls are bypassed. RBAC is a core security mechanism in the system and is designed to minimize privilege exposure, reduce attack surface area, and enforce the principle of least privilege across all system components.

3.1.3 Multi-Factor Authentication and Token-Based Security

Description:

The system implements a secure authentication mechanism combining multiple security factors and modern session management techniques.

Authentication is based on **knowledge factors** (such as passwords) and **possession factors** (such as OTPs delivered via email, SMS, or authenticator applications). This multi-factor approach significantly reduces the risk of unauthorized access due to credential compromise.

Upon successful authentication, the system issues cryptographically secure, token-based credentials. Separate tokens are used for short-lived access and longer-lived session renewal, ensuring that compromised tokens have limited impact. Access tokens are designed to expire quickly, while refresh tokens are tightly controlled and can be revoked when suspicious activity is detected.

All authentication attempts, token issuance events, and session-related actions are logged for auditing and anomaly detection. Together, these measures provide strong protection against common attack vectors such as credential stuffing, session hijacking, and replay attacks.

3.1.4 Centralized Admission Control, Rate Limiting and Traffic Protection

Description:

The system includes a dedicated admission control layer responsible for regulating and protecting all incoming requests before they reach internal application services. This layer acts as a security and traffic-governance boundary, enforcing global and tenant-aware policies to prevent abuse, overload, and unauthorized access. All incoming traffic is first normalized and securely terminated by an external gateway responsible for encrypted communication handling and request distribution. After this initial processing, requests are forwarded to the admission control layer, where security and rate-governing decisions are applied.

The admission control layer enforces **multi-level rate limiting and throttling policies**, including:

- **Global rate limits**, used to detect abnormal traffic spikes and trigger system-wide protective measures or alerts.
- **Per-tenant rate limits**, ensuring fair resource usage across organizations and preventing one tenant from degrading system availability.
- **Per-endpoint rate limits**, protecting sensitive or high-risk operations such as authentication, OTP generation, and file uploads from brute-force and abuse attacks.

In addition to rate limiting, the system supports IP-based traffic control, allowing requests to be explicitly allowed or denied based on source address. This includes configurable IP whitelisting for trusted networks and blacklisting for known malicious or suspicious sources.

3.1.5 Database-Level Cryptographic Protection

Description:

The system enforces strong cryptographic protections at the database layer to safeguard sensitive information against unauthorized access and data breaches.

Authentication credentials and security-sensitive secrets are never stored in plaintext. Instead, they are processed using irreversible hashing mechanisms before persistence, ensuring that original values cannot be reconstructed even if the database is exposed.

Sensitive data that must remain retrievable, such as personal identifiable information, medical metadata, and secure references to uploaded documents, is stored in encrypted form at rest. Encryption keys are managed independently from the data store, preventing direct data disclosure through database-level access alone.

Integrity protections are applied to critical records to ensure that unauthorized modifications can be detected during audits. Security-critical fields are either cryptographically protected or validated through server-side verification mechanisms before use.

Decryption operations are strictly confined to authorized server-side components operating within controlled execution boundaries. Encrypted or hashed values are never exposed directly to client applications or external systems.

This approach ensures that a compromise of the storage layer does not directly result in credential leakage, identity exposure, or disclosure of medical data, reinforcing the system's security posture in alignment with healthcare-grade data protection practices.

3.1.6 Patient Medical Identity

Description:

Each patient in the system is associated with a persistent medical identity that serves as the authoritative clinical representation of the individual across all healthcare interactions.

The medical identity aggregates critical health information required for safe and effective medical care, including demographic attributes, blood type, documented allergies, chronic conditions, active diagnoses, prescribed medications, and emergency contact information. This data forms a unified, longitudinal view of the patient's medical state rather than isolated or session-based records.

To preserve clinical accuracy and prevent self-reporting errors, the system **enforces strict role based ownership of medical data updates**. Patients are permitted to manage non-clinical and safety-related information, such as emergency contact details, ensuring that this data remains current and reliable in urgent situations.

Clinical attributes, such as allergies, chronic conditions, diagnoses, and prescribed medications, are exclusively created and modified by authorized healthcare providers. Each such entry is explicitly linked to the responsible provider and associated clinical context, ensuring traceability and medical accountability.

The system maintains historical continuity of the medical identity by retaining timestamps and clinical authorship for all medical entries. This guarantees that patient data reflects verified medical decisions rather than unvalidated user input, while still allowing patients to view their complete medical profile.

3.1.7 Patient Health Journal and Recovery Self-Tracking

Description:

The system provides patients with a personal health journal that enables structured self-reporting of their day-to-day health status throughout the course of a specific diagnosis.

For each active or historical diagnosis, patients can record periodic health notes describing their subjective condition and recovery progress. These entries include both quantitative indicators, such as mood, pain level, and energy level, and qualitative free-text notes that allow patients to contextualize how they are feeling in their own words.

Health journal entries are explicitly linked to the associated diagnosis and date, forming a chronological view of the patient's recovery journey. This allows patients to reflect on symptom progression over time while preserving a clear distinction between self-reported observations and clinically verified medical records.

Journal entries are owned and managed exclusively by the patient and do not alter diagnoses, medications, or other clinician-controlled medical data. Healthcare providers may reference these notes during clinical encounters to gain additional insight into the patient's lived experience, without treating them as diagnostic conclusions.

The system is designed to support future extensions in which patient-reported data can be analyzed to provide contextual guidance or wellness suggestions. While such capabilities are not part of the

current implementation, the journal structure establishes a foundation for advanced patient support features without compromising clinical boundaries.

This feature encourages patient engagement, improves continuity of care, and empowers individuals to actively participate in monitoring their health outside of formal medical visits.

3.1.8 Patient Medical History

Description:

The system maintains a comprehensive, longitudinal medical history for each patient, serving as the central record of all clinically relevant events over the patient's lifetime within the platform.

Medical history entries are organized in a chronological structure, grouped by clinical encounters and ordered by time, ensuring a clear and traceable progression of the patient's health status. Each record within the medical history is explicitly linked to its originating context, such as diagnoses, prescribed medications, laboratory results, imaging studies, and clinical notes.

To support interoperability and structured medical representation, the system encodes clinical data using internationally recognized medical classification standards. Diagnoses and conditions are recorded using **ICD-11** codes, while clinical concepts and terminology are represented using **SNOMED-based** structures where applicable. This approach ensures consistency, reduces ambiguity, and enables reliable aggregation and analysis of medical data.

Patients retain full control over access to their medical history. Visibility of medical records is governed through explicit, patient-issued access permissions, allowing patients to determine who can view their history, what portions are accessible, and for how long. Access control is enforced at the record level, preventing unauthorized disclosure of sensitive health information.

Medical history records are immutable from the patient's perspective. Patients may view their complete history but cannot modify clinician-authored medical records, preserving clinical integrity and auditability. All access to medical history data is logged for accountability and traceability.

This feature establishes the medical history as the authoritative source of truth within the system, balancing structured clinical data, patient ownership, and controlled access.

3.1.9 Clinical Encounters and Authorized Care Provision

Description:

Clinical interactions between a patient and a healthcare provider are conducted through formally authorized encounters within the system.

Prior to an encounter, the patient generates a time-limited access code that defines the scope of permissions granted to the healthcare provider. These permissions determine the level of access to the patient's medical history, such as read-only or read-write access, and are strictly enforced for the duration of the encounter.

Once access is granted, the healthcare provider can review the authorized portions of the patient's medical history and initiate a new clinical encounter. During the encounter, the provider documents presenting symptoms, clinical observations, diagnoses, and treatment decisions in a structured manner.

Healthcare providers can prescribe medications, request laboratory or imaging investigations, and schedule follow-up appointments directly within the encounter context. All actions performed by the provider are explicitly linked to the encounter and attributed to the responsible clinician.

Upon completion, the encounter becomes a permanent part of the patient's medical history, ensuring continuity of care and traceability across future interactions. Access granted for the encounter expires automatically based on the patient-defined constraints, preventing prolonged or unintended access.

This feature enforces patient-controlled access while enabling healthcare providers to deliver documented, accountable, and continuous care.

3.1.10 Automated Medical Notifications and Patient Reminders

Description:

The system includes an integrated notification and reminder mechanism to ensure that patients remain informed and engaged with their care plans.

Medications prescribed during clinical encounters are automatically converted into medication reminders based on dosage instructions and scheduling information. Laboratory and imaging orders issued by healthcare providers generate corresponding reminders, notifying patients of required tests and follow-up actions.

Scheduled follow-up appointments are similarly transformed into time-based reminders, ensuring that patients are aware of upcoming clinical visits or evaluations. All reminders are generated automatically from clinician-authored data, eliminating the need for manual patient input.

Patients can access and manage all reminders through a dedicated reminders interface, where notifications are categorized by type and status. Reminder delivery and status changes are tracked to ensure reliability and transparency.

3.1.11 Laboratory Test Ordering and Result Integration

Description:

The system supports laboratory workflows by enabling healthcare providers to request diagnostic tests as part of a clinical encounter.

Laboratory orders are issued within the context of an authorized encounter and are linked directly to the corresponding patient and medical history record. Patients grant laboratories access through controlled mechanisms that allow test execution and result submission without exposing the broader medical history.

Laboratories do not have visibility into patient medical history, diagnoses, or prior encounters. Their access is strictly limited to the specific test order and its required metadata.

Once test results are uploaded, they are securely attached to the originating medical order and automatically incorporated into the patient's medical history under the relevant encounter. This ensures continuity and traceability without expanding laboratory access privileges.

This design isolates diagnostic service providers from clinical records while maintaining a unified and complete patient medical history.

3.1.12 Medical Imaging Requests and Result Association

Description:

The system enables healthcare providers to request imaging studies as part of clinical encounters, including modality selection and clinical indications.

Imaging centers receive only the information necessary to perform the requested study and submit diagnostic results. They are not granted access to the patient's medical history, diagnoses, or other clinical records beyond the scope of the imaging order.

Uploaded imaging results and associated documents are automatically linked to the originating order and embedded into the patient's medical history under the corresponding encounter. This preserves clinical context while maintaining strict access boundaries.

By separating imaging execution from medical history access, the system ensures data minimization, confidentiality, and proper attribution of diagnostic results.

3.1.13 Administrative Verification and Account Governance

Description:

The system provides administrators with a dedicated verification interface used to review and process user registration applications.

All newly registered users requiring institutional approval appear in a centralized verification queue. For each application, the administrator can review submitted information and supporting documents before taking an explicit action. Applications can be either verified, granting the user access to the system, or rejected with an associated rejection reason.

The administrator's role in this context is strictly limited to account verification and lifecycle control. Administrators do not participate in clinical workflows or access patient medical data, ensuring a clear separation between administrative authority and healthcare operations.

This feature ensures that all system users are vetted before activation, reinforcing trust and accountability across the platform.

3.1.14 Audit Log Review and User Suspension Management

Description:

The system maintains detailed audit logs capturing security-sensitive and access-related actions across all users.

Administrators have access to a dedicated audit review interface that allows them to inspect user activities, including access attempts, data interactions, and system actions. Audit entries provide sufficient contextual information to support security investigations and behavioral analysis.

Based on audit findings, administrators can take enforcement actions against user accounts exhibiting suspicious or policy-violating behavior. This includes suspending accounts to immediately restrict access while preserving all associated data and records.

Suspension actions are applied without modifying or deleting existing medical or system data, ensuring that investigations can be conducted without data loss. All administrative enforcement actions are themselves logged for accountability.

This feature enables active system governance while maintaining transparency and traceability.

3.1.15 User Reports and Support Request Management

Description:

The system includes a reporting and support interface that allows users to submit bug reports, system issues, or support requests.

All submitted reports are routed to the administrative portal, where they are categorized and tracked for resolution. Administrators can review report details, monitor their status, and take appropriate follow-up actions.

This feature establishes a formal feedback and support channel between users and system administrators, enabling continuous system improvement and operational stability without exposing internal system controls to end users.

3.2 Non-Functional Requirements

3.2.1 Security and Privacy

The system prioritizes security and privacy as foundational qualities due to the sensitive nature of medical and personal data.

All access to protected resources is governed by strict authentication and authorization controls. Role-based access enforcement ensures that users can only perform actions explicitly permitted by their role and granted permissions.

Sensitive data is protected both in transit and at rest using industry-accepted cryptographic practices. Authentication credentials and security artifacts are never stored in plaintext, and access to decrypted data is restricted to trusted server-side components.

All security-relevant actions, including authentication events, data access, and administrative actions, are recorded in immutable audit logs. These logs support accountability, incident investigation, and compliance verification.

The system enforces data minimization by ensuring that external entities such as laboratories and imaging centers only access information required to fulfill their tasks, without exposure to broader patient medical history.

3.2.2 Performance and Scalability

The system is designed to maintain responsive performance under normal and peak usage conditions.

Core operations such as authentication, medical record retrieval, and encounter creation are optimized to complete within acceptable response times. The architecture supports horizontal scaling to accommodate increased user load without degradation of service quality.

Rate limiting and traffic control mechanisms protect the system from abuse and prevent resource exhaustion caused by malicious or accidental overload.

The system supports gradual growth in the number of users, medical records, and diagnostic data without requiring structural redesign.

3.2.3 Availability and Reliability

The system is designed to provide high availability and consistent service access for all user roles.

Critical components are isolated to prevent localized failures from propagating across the system.

Fault-tolerant mechanisms ensure that partial failures do not compromise system integrity or data consistency.

Medical records and clinical data are persisted reliably, and the system prevents data corruption through transactional guarantees and controlled write operations.

In the event of failures or maintenance operations, the system maintains predictable behavior and preserves data integrity.

3.2.4 Maintainability and Extensibility

The system architecture emphasizes modularity and separation of concerns to simplify maintenance and future enhancements.

Core domains such as authentication, medical records, encounters, diagnostics, and notifications are logically isolated, enabling changes to be introduced without widespread impact.

The system is designed to support future extensions, including advanced analytics, decision support tools, and intelligent patient assistance, without requiring fundamental changes to existing workflows.

Clear boundaries between clinical logic, administrative functions, and infrastructure concerns improve long-term maintainability.

3.2.5 Usability and Accessibility

The system provides role-specific user interfaces tailored to the needs of patients, healthcare providers, diagnostic centers, and administrators.

User workflows are designed to minimize cognitive load and reduce the likelihood of errors, particularly in clinical data entry and access authorization processes.

Patients can easily view their medical history, manage access permissions, and interact with reminders and notifications without requiring medical or technical expertise.

Consistent interface behavior across features improves learnability and user confidence.

3.2.6 Auditability and Compliance Readiness

The system is designed with auditability as a core non-functional requirement.

All access to patient data, administrative actions, and security-sensitive operations are traceable through structured audit logs. These logs provide sufficient context to reconstruct actions and assess compliance with internal policies and regulatory expectations.

The use of standardized medical terminologies and structured clinical data supports interoperability and regulatory alignment with healthcare data governance standards.

3.2.7 Data Integrity and Consistency

The system enforces strong data integrity constraints to ensure the accuracy and consistency of medical records.

Clinical data authored by healthcare providers is protected from unauthorized modification, while patient-generated data is clearly distinguished from clinician-verified records.

Relationships between encounters, diagnoses, medications, and diagnostic results are strictly maintained to preserve clinical context and historical accuracy.

3.3 System Models

3.3.1 Entity Relationship Diagram

3.3.2 Data Flow Diagram

3.3.3 Use Case Diagram

3.3.4 Database Schema

3.4 Target Audience & Visual Identity

Target Audience

Sijill is designed for a national healthcare ecosystem, not a niche product.

- **Primary users:**

- o **Patients:** Citizens who need a single, lifelong medical record they can access and control easily.
- o **Healthcare Providers:** Doctors and clinicians who require fast, reliable access to complete patient histories for safe decision-making.

- **Secondary users:**

- o **Laboratories & Imaging Centers:** Entities responsible for securely uploading diagnostic results with minimal access scope.
- o **System Administrators (Governmental):** Authorized personnel responsible for user verification, governance, and audit oversight.

The system assumes **varying levels of technical literacy**, especially among patients, so clarity and simplicity are non-negotiable.

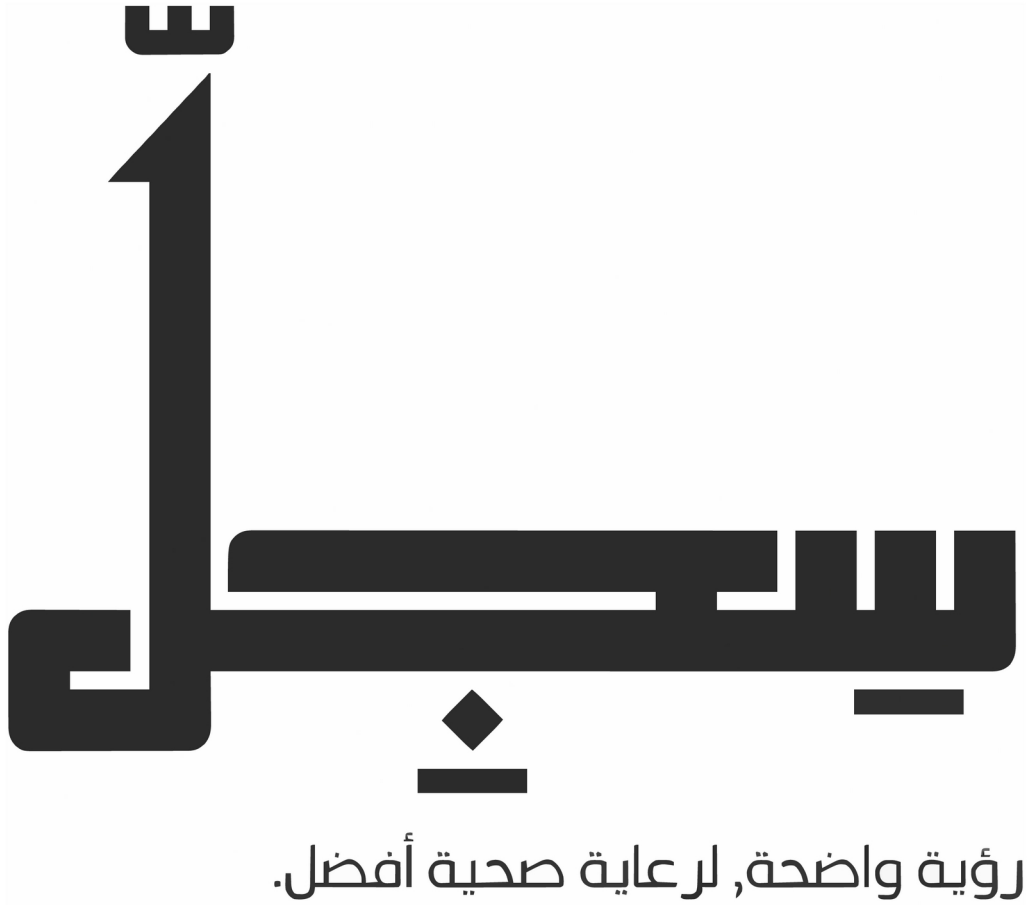
Visual Identity

The visual identity of Sijill prioritizes **trust, clarity, and authority**.

- **Design principles:** Minimalistic, clean layouts with strong visual hierarchy to reduce cognitive load.
- **Color palette:** Neutral and calm colors (e.g., blues, grays, whites) to convey reliability, security, and medical professionalism.
- **Typography:** Clear, highly legible fonts suitable for long medical records and frequent daily use.
- **Iconography & UI elements:** Simple and functional, avoiding decorative complexity that could confuse users.

Overall, the visual identity supports Sijill's role as critical national infrastructure: professional, sober, and focused on usability rather than aesthetics for flexing.

System Logo:



4. Methodology

This chapter transitions from the analytical foundation of the project to the concrete design and implementation phases. It details the architectural decisions, technology selections, design patterns, and development methodologies employed to realize the Sijill system. The chapter is structured to provide a clear technical blueprint, beginning with the high-level system design and progressively detailing the specific implementation strategies.

4.1 System Design

The design of the Sijill system was guided by the core principles of security, patient centricity, interoperability, and maintainability established during the requirements analysis. The primary objective was to architect a robust, scalable platform that enforces strict data governance while providing intuitive interfaces for its diverse user base: patients, healthcare providers, diagnostic centers, and administrators. The design follows a modular, layered approach to ensure separation of concerns, facilitating independent development, testing, and future evolution of system components.

4.1.1 System Architecture

The Sijill system is architected using a **modular monolithic** pattern within a classic **client-server** model. This approach organizes the application into discrete, well-defined functional modules (e.g., user management, clinical encounters, diagnostics) within a single deployable unit. This structure provides the simplicity of a monolith for development and deployment while maintaining the logical separation and maintainability benefits often associated with microservices. The system is designed to be cloud-ready, with clear boundaries that allow for the future extraction of specific modules into independent microservices should scaling demands require it. The high-level architectural overview, depicted in the diagram below, consists of the following core layers and components:

- **Client Layer:** This layer encompasses all end-user interfaces. It includes a cross-platform **Patient Mobile Application** (Flutter), a **Healthcare Provider Web Portal**, an **Administrative Web Dashboard**, and dedicated, limited-functionality **web portals for Laboratories and Imaging Centers**.

- **Presentation & Security Gateway Layer:** All external client traffic is routed through this layer, which acts as the primary security and traffic control boundary. It is implemented in two tiers:

- 1. **NGINX Reverse Proxy:** Serves as the initial entry point, handling TLS termination, SSL offloading, and static file serving.

- 2. **Custom Traffic Control Reverse Proxy:** A custom-built component that enforces application-level admission control policies, including global and role-based rate limiting, IP whitelisting/blacklisting, and request sanitization before forwarding to the core application.

- **Application Layer:** The heart of the system, this layer hosts the core RESTful API built as a modular monolith. It contains all the business logic for user management, clinical workflows, diagnostic order processing, and audit logging. It processes requests from the gateway, enforces Role-Based Access Control (**RBAC**), executes business rules, and coordinates data persistence. Security mechanisms such as token validation, data encryption/decryption for sensitive fields, and business logic validation are centralized here.

- **Data Layer:** This layer is responsible for the secure and reliable persistence of all system data. It comprises:

- o **Main Operational Database:** Stores all structured data, including user profiles, medical histories, clinical encounters, and diagnostic orders/results.

- o **Audit Database:** A separate, immutable log store that records all security-sensitive events (logins, data access, administrative actions) for compliance and forensic analysis.

- o **Local File Storage:** Used for storing unstructured documents such as uploaded identification proofs, medical report PDFs, and diagnostic images (**DICOM** files), with metadata managed in the main database.

- **External Services Layer:** The system interfaces with external services via secure APIs. This primarily includes integration with medical terminology standards (e.g., **ICD-11**, **SNOMED CT** lookups) for structured data entry. Future extensibility points for SMS/email gateways for OTP delivery or payment processors are also accounted for in this layer.

4.1.2 Technology Stack

The technology stack for the Sijill system was selected to meet the dual demands of academic prototyping and production-grade readiness. The primary goals were developer velocity, architectural enforceability, strong security posture, and foundational scalability. The resulting stack is a cohesive, modern ecosystem centered on TypeScript, ensuring consistency and efficiency across all development layers.

- **Backend Runtime & Framework:** The core server is built on **Node.js**. The **NestJS** framework was chosen over more minimal alternatives for its opinionated, modular architecture. **NestJS** enforces dependency injection, layered design, and strict separation of concerns, which proved essential for maintaining code quality and consistency across a multi-developer team working on a complex domain.
- **Database: PostgreSQL** was selected as the primary relational database management system. Its full ACID compliance, robust support for complex queries and transactions, and proven scalability made it the ideal fit for the structured, highly relational nature of Electronic Health Record data.
- **Client Applications:** The patient-facing interface is a cross-platform mobile application developed with Flutter, allowing a single codebase to target both **iOS** and **Android** with native performance. The healthcare provider and administrative portals are web applications built with React and TypeScript. Using TypeScript across the frontend and backend created a unified development experience, improved code safety through static typing, and facilitated sharing of type definitions.
- **API & Integration:** The system exposes a **RESTful API** as its primary integration layer. The API is formally documented using the OpenAPI (**Swagger**) specification, providing clear, interactive documentation for developers. Integration with medical coding standards is achieved via dedicated APIs served from local **ICD-11** and **SNOMED CT** Docker containers, ensuring offline availability and fast terminology lookups during clinical data.
- **Infrastructure & Development Tools:**
 - o **File Storage:** Uploaded documents (e.g., lab reports, identification scans) are managed via a logically structured local filesystem, with metadata stored in PostgreSQL. This design allows for a straightforward future migration to cloud object storage if required.
 - o **Version Control & Collaboration:** The project is organized within a GitHub Organization, with code separated into five distinct repositories: backend, patient portal, staff-portal, admin-portal, and documentation.
 - o **Containerization: Docker** is used to containerize the backend application and database, ensuring consistent runtime environments and simplifying the setup process for development and testing.
 - o **Testing:** A comprehensive testing strategy was executed, encompassing unit tests, integration tests, end-to-end workflow tests, and performance testing.

4.1.3 Design Patterns

The Sijill system leverages several established software design patterns, largely facilitated by the NestJS framework's built-in architectural paradigms. These patterns were intentionally employed to enhance code organization, promote maintainability, enforce separation of concerns, and facilitate testing throughout the development lifecycle.

The key design patterns implemented in the system include:

1. Dependency Injection (DI): This is the foundational pattern of the NestJS framework. All major components, including services, controllers, repositories, and modules, are designed as injectable classes. The framework's DI container manages the instantiation and lifecycle of these dependencies, automatically injecting them where needed. This pattern decouples class dependencies from their implementations, making the codebase more modular, testable, and flexible. For example, the Encounter Service depends on the Patient Repository and Diagnosis Service, which are injected via its constructor, not hardcoded.

2. Repository Pattern: Applied to abstract data layer access. Instead of scattering database queries throughout the business logic, dedicated Repository classes (e.g., Patient Repository, Encounter Repository) are created. These repositories expose clean, domain-specific methods (like `findPatientById`, `save Encounter`) while encapsulating the raw SQL or ORM queries. This centralizes data access logic, simplifies data mocking for unit tests, and makes the underlying database technology easier to swap if needed.

3. Service Layer Pattern: Core business logic is encapsulated within Service classes (e.g., Auth Service, Medical Record Service, Order Service). These services orchestrate operations, enforce business rules, and coordinate between multiple repositories and other services. Controllers remain thin, responsible only for handling HTTP requests, validating input, and returning responses, while delegating all complex operations to the appropriate service.

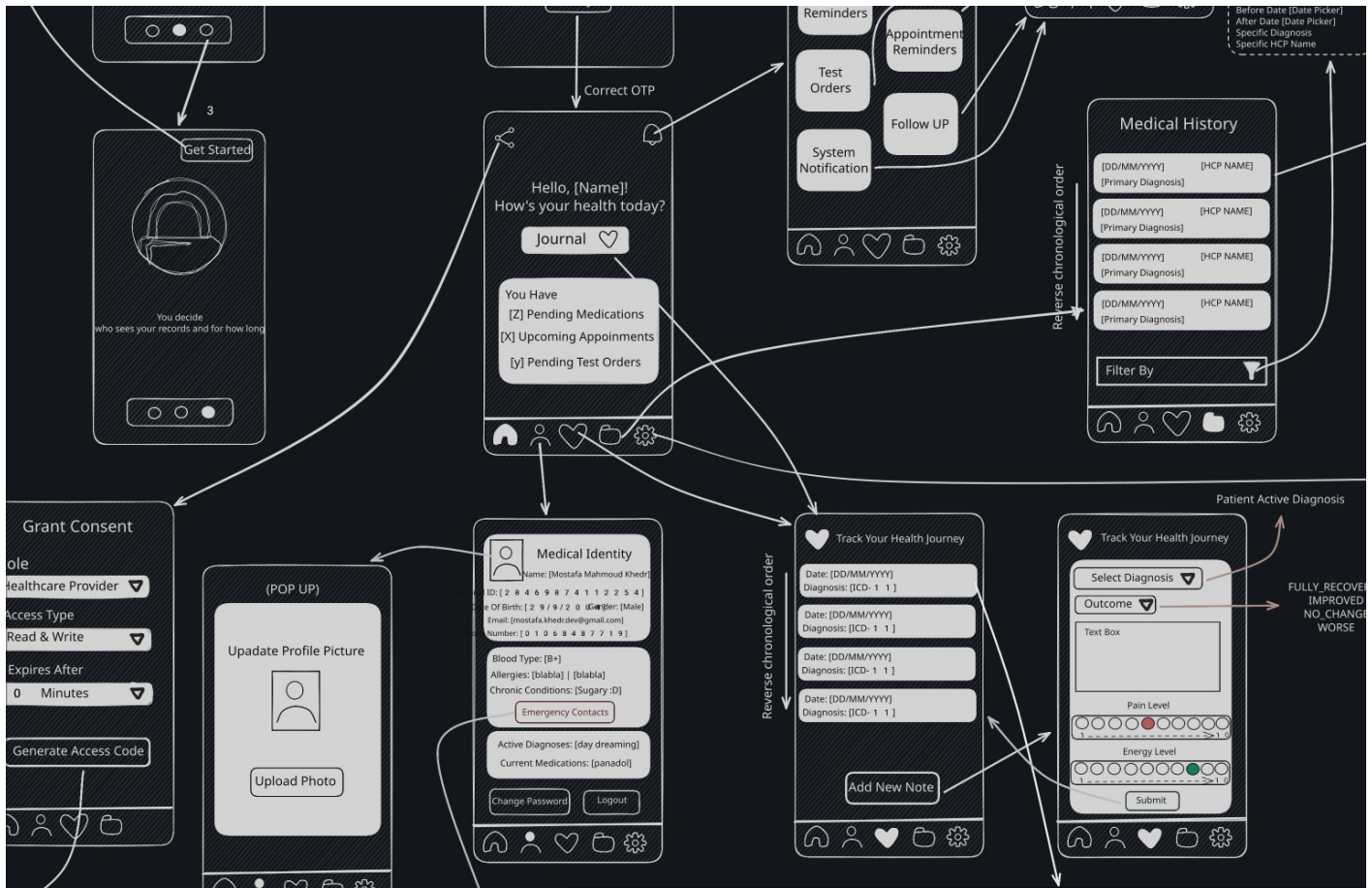
4. Module Pattern: The entire application is organized into feature modules (e.g., AUTH Module, Patient Module, Clinical Module). Each module is a cohesive block of code dedicated to a specific business domain. It encapsulates related controllers, services, and repositories, declaring its own imports, providers, and exports. This pattern enforces strong boundaries between different parts of the application, preventing circular dependencies and making the system's structure intuitive and scalable.

These patterns, ingrained in the NestJS framework's philosophy, provided a disciplined structure for the development team. They ensured that the codebase remained organized, testable, and aligned with clean architecture principles, directly supporting the project's goals of creating a maintainable and scalable system foundation.

4.1.4 UI/UX Design

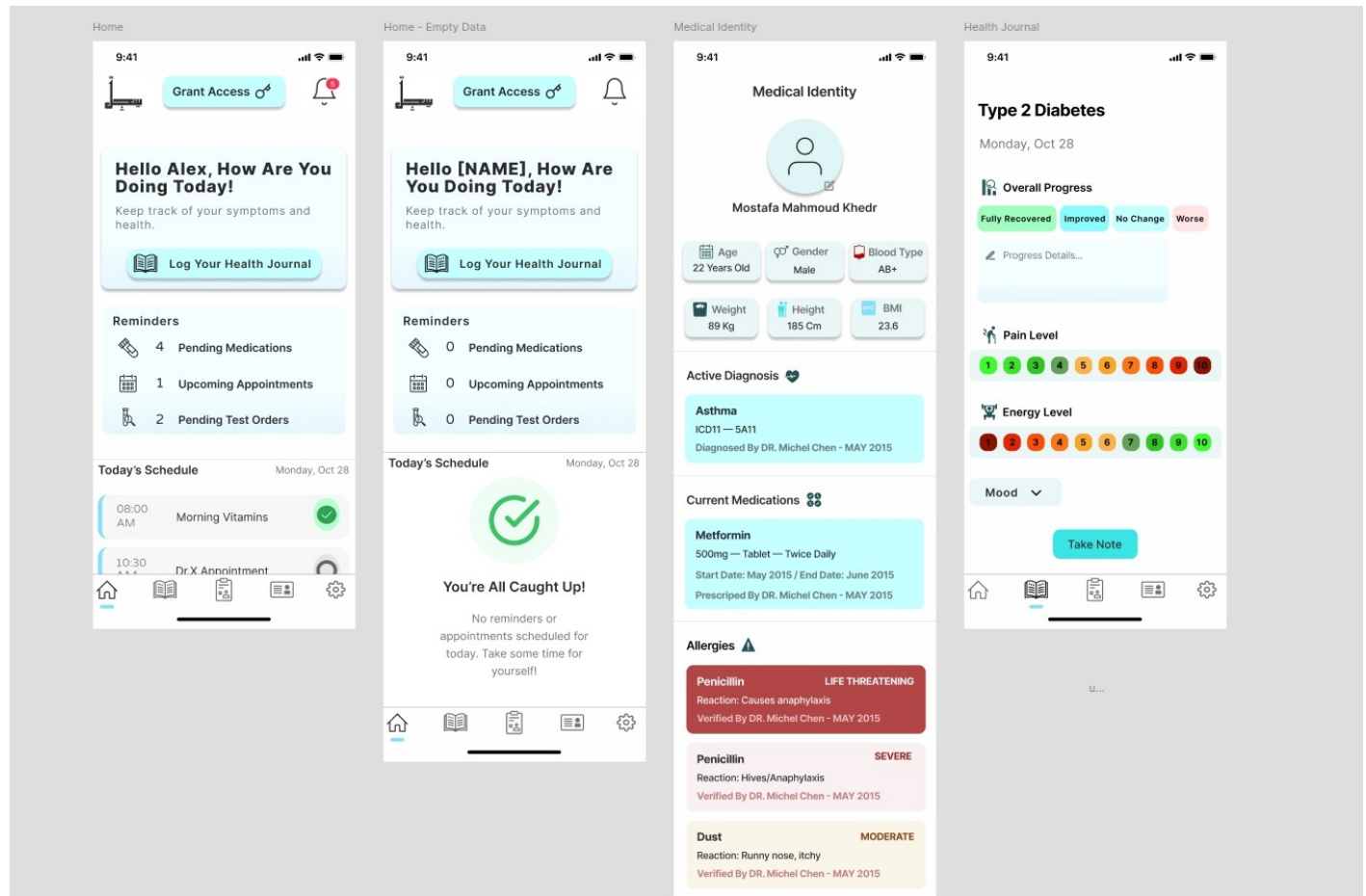
Phase 1: Information Architecture & Wireframing:

Low-fidelity wireframes were created using **Excalidraw** to map out screen layouts, navigation flows, and key interactions. This phase focused on structuring content logically, such as patient medical timelines, clinical encounter forms, and administrative dashboards, without visual styling.



Phase 2: Visual Design & High-Fidelity Prototyping

Wireframes were translated into polished, interactive prototypes using **Figma**. A cohesive visual identity, including a professional color palette, consistent typography, and a reusable component library, was established. Interactive states, responsiveness, and accessibility considerations were finalized.



4.2 Implementation

4.2.1 Development & Environment Tools

A consistent development environment was established using industry-standard tools to ensure code quality, collaboration efficiency, and deployment reliability.

Version Control & Collaboration:

- **Git with GitHub Organizations** managed the codebase across five repositories:
 - sijill-backend – Core API and business logic
 - sijill-patient-portal – Flutter mobile application
 - sijill-staff-portal – React web portal for healthcare providers
 - sijill-admin-portal – React web dashboard for administrators
 - sijill-docs – Project documentation and reports

Containerization & Local Development:

- **Docker** and **Docker Compose** containerized the backend API, PostgreSQL database, Redis cache, and medical terminology services (ICD-11/SNOMED CT local APIs). This provided a reproducible development environment and simplified onboarding for new team members.

API Development & Testing:

- **Postman** was used for manual API endpoint testing, request/response validation, and workflow simulation.
- **Swagger/OpenAPI** auto-generated interactive API documentation from code annotations, serving as both developer reference and testing interface.

Package Management & Scripting:

- **NPM** managed backend dependencies, with scripts for building, testing, and database migrations.
- **Yarn** handled Flutter and React project dependencies for consistent package resolution.

Editor & IDE Configuration:

- **VS Code** was the primary IDE, with shared workspace settings and extensions for **TypeScript**, **Dart**, **ESLint**, and **Prettier** to enforce consistent code formatting across the team.

Medical Terminology Integration:

- Locally run **Docker** containers hosted **ICD-11** and **SNOMED CT** terminology services, allowing offline development and fast lookups without reliance on external APIs during testing.

4.2.2 Back-End Implementation

The backend was implemented as a modular monolith using NestJS, structured around core business domains and following Clean Architecture principles.

Module Organization:

- Auth Module: Handled user registration, multi-factor authentication (**JWT**, **OTP**), and session management.
- User Module: Managed profiles, role-based permissions (**RBAC**), and administrative verification workflows.
- Patient Module: Centralized medical identity, demographics, and emergency information.
- Clinical Module: Orchestrated encounter lifecycle, diagnosis tracking (**ICD-11**), and prescription management.
- Diagnostic Module: Processed lab and imaging orders, results submission via secure upload portals.

Security Implementation:

- Authentication: **JWT**-based stateless authentication with short-lived access tokens and secure refresh token rotation.
- Authorization: Guard decorators enforced RBAC at endpoint level
- Data Protection: Sensitive fields (PII, credentials) encrypted at rest using **Node.js** crypto. Passwords hashed with bcrypt.
- Admission Control: Custom reverse proxy (**TrafficCTRL**) enforced rate limiting, IP filtering, and request validation before reaching core API.

Database & ORM:

- **TypeORM** served as the primary ORM, mapping entities to PostgreSQL tables with relations (One-to-Many, Many-to-One).
 - Database Migrations: Version-controlled migration scripts managed schema evolution.
 - Redis: Cached rate-limit counters, session blacklists, and frequently accessed reference data.
- Medical Standards Integration:
- Structured clinical data used **ICD-11** for diagnoses and **SNOMED CT** for clinical terms via internal service calls to local terminology containers.
 - DICOM Handling: Metadata extraction and secure storage routing for medical imaging files.

API Design:

- **RESTful** endpoints followed resource-based naming conventions.
- Consistent response/error formatting with HTTP status codes.
- Request validation via built-in NestJS Pipes and custom **DTOs** (Data Transfer Objects).

4.2.3 Frontend Implementation

The frontend comprises three distinct applications, each tailored to its user role while sharing design language and security patterns.

Patient Mobile Application (Flutter):

- State Management: Provider package managed application state for user sessions, medical records, and notifications.
- Key Features:
 - o Secure authentication flow with JWT storage.
 - o medical timeline view displaying encounters, lab results, and prescriptions chronologically.
 - o OTP generator for granting time-bound access to healthcare providers.
 - o Emergency QR code displaying critical info (blood type, allergies).
 - o Push notification handling for reminders and alerts.
- Responsive Design: Adaptive layouts for various mobile screen sizes.

Healthcare Provider Portal (React + TypeScript):

- State Management: Context API and hooks managed user state and clinical session data.
- Core Components:
 - o Dashboard with patient panel and upcoming appointments.
 - o Clinical encounter form with integrated ICD-11/SNOMED CT search.
 - o Order creation interface for labs and imaging.
 - o Patient record viewer (activated via OTP entry).
- Security: Axios interceptors attached JWT to requests; automatic token refresh.

Administrative Portal (React + TypeScript):

- Functionality: User verification queue, audit log viewer, system report dashboard, and account suspension controls.
- Design: Data-table components for managing large datasets with filtering and pagination.

Shared Infrastructure:

- API Communication: Typed API clients generated from OpenAPI spec ensured frontend backend contract consistency.
- Routing: React Router (web) and Flutter Navigator (mobile) handled navigation with role-based route protection.

Responsive & Accessible Design:

- CSS Grid/Flexbox created responsive web layouts.
- ARIA labels, sufficient contrast ratios, and keyboard navigation support met accessibility standards.

4.2.4 Testing Approaches

A multi-layered testing strategy ensured system reliability, security, and performance across all components.

Backend Testing:

- **Unit Tests:** Jest tested individual services, repositories, and utilities in isolation (mocked dependencies).
- **Integration Tests:** Verified module interactions, database operations, and API endpoint contracts using test databases.
- **E2E Tests:** Supertest simulated full HTTP request/response cycles for critical user workflows (registration → OTP → encounter creation).

Frontend Testing:

- **Unit Tests:** Jest + React Testing Library validated UI components and business logic.
- **Widget Tests:** Flutter's widget tester verified mobile UI components and interactions.
- **Integration Tests:** Cypress (web) and Flutter Integration Tests (mobile) automated user scenarios across frontend and backend.

Security Testing:

- **Penetration Testing:** Manual and automated scans (OWASP ZAP) tested for common vulnerabilities (XSS, CSRF, SQLi).
- **Authentication/Authorization Tests:** Verified RBAC enforcement and token validation.
- **Audit Log Verification:** Confirmed all sensitive actions were properly logged and immutable.

Performance Testing:

- **Load Testing:** k6 simulated concurrent users for critical endpoints (login, record retrieval, OTP generation).
- **Stress Testing:** Identified breaking points under extreme load for admission control and database layers.
- **Caching Validation:** Verified Redis effectiveness in reducing database load for high frequency requests.

API & Contract Testing:

- **Postman Collections:** Automated regression tests for all REST endpoints.
- **OpenAPI Validation:** Ensured API implementation matched documented specification.

4.3 Results & Evaluation

The Sijill prototype was successfully designed, implemented, and evaluated across its core functional domains. The outcomes of the development process are assessed here against the objectives and requirements defined in Chapter 3, providing a comprehensive account of what was achieved, how it was validated, and what the implementation demonstrated.

Implemented Functional Scope

The backend, built as a modular NestJS monolith and documented through formal OpenAPI specifications, delivered a fully operational RESTful API covering five primary functional modules. The Authentication Module implemented the complete multi-factor authentication lifecycle, from initial registration through OTP email verification, administrative approval, and ultimately MFA-enforced login with short-lived JWT access tokens and rotating refresh tokens. The implementation correctly handles platform-specific behavior, returning the refresh token in the response body for the mobile client while setting it as an HTTP-only cookie for web clients, reflecting a security-conscious design decision appropriate to each platform's threat model.

The Patient Module delivered a comprehensive patient-facing feature set accessible through the mobile application. Patients can view and interact with their Medical Identity, which aggregates blood type, active diagnoses, current medications, allergies, and chronic conditions into a unified clinical profile. Emergency contacts are fully manageable, including primary contact designation and automatic demotion of the previously designated primary contact upon reassignment. The Health Journal enables patients to log structured daily entries against active diagnoses, recording quantitative indicators such as pain level and energy level alongside a qualitative mood note. Each journal entry triggers an AI-generated health snapshot via the Gemini API, providing contextual wellness guidance tailored to the patient's full medical context. The feature is designed to degrade gracefully; if the AI call fails for any reason, the entry is still persisted and the response includes an explicit UNAVAILABLE status with a human-readable reason, ensuring that the core journaling workflow is never interrupted by third-party service unavailability. The Medical History module provides patients with a chronological list of all clinical encounters, along with a detailed encounter view presenting the symptoms, diagnoses, and prescriptions documented during each visit.

The Clinical Module implemented the system's most architecturally complex and privacy critical feature: the patient-controlled permission token mechanism. Patients generate time-limited, 6-digit numeric tokens specifying the intended entity type and access scope. These tokens are stored hashed on the server and are displayed in plaintext exactly once, mirroring the security model of one-time

passwords. Healthcare providers redeem a token to establish a scoped Clinical Session, within which they can view the authorized portions of the patient's medical record and create a new Clinical Encounter. The encounter creation endpoint accepts structured data including presenting symptoms, diagnoses with ICD-11 codes and titles, prescriptions, and medical orders for laboratories and imaging centers, and automatically generates the corresponding patient reminders and notifications upon successful completion. Laboratories and imaging centers operate through an analogous but strictly upload-only session model, preventing any access to the broader patient record and enforcing the principle of least privilege as described in Section 3.2.1.

The Administrative Module provided a functional verification interface through which administrators can review the verification queue of pending users, inspect submitted documents grouped by category, and issue approve or reject decisions with mandatory rejection reasons recorded for audit purposes. The module additionally exposes system statistics counters for each user role, providing administrators with an overview of platform growth and activity.

The Reminders and Notifications Module delivered automated lifecycle management for all three reminder types: medication, appointment, and medical order. Patient-facing APIs support listing, grouping by type, and updating reminders, alongside a notification inbox supporting pending consumption, delivery status tracking, and read-state management.

Finally, the ICD-11 Module integrated the locally deployed WHO ICD-11 API container, providing a search endpoint that returns up to six diagnosis suggestions for any given query term of at least two characters. This integration enables structured and internationally standards compliant diagnosis entry during clinical encounters. The local deployment approach ensured offline availability and consistently fast response times throughout development and testing, independent of external network conditions.

API Documentation and Contract Completeness

The entire API surface was formally specified using the OpenAPI 3.0 standard across six contract documents, covering authentication, patient features, clinical workflows, administrative operations, reminders and notifications, ICD-11 search, and the patient home screen. Each contract defined request and response schemas, HTTP status codes, security requirements, and usage examples. This documentation served both as the authoritative developer reference and as the binding contract for frontend–backend integration, ensuring consistency across the five project repositories.

Testing and Validation

The system was validated through a multi-layered testing strategy, as detailed in Section 4.2.4. Unit tests verified individual service methods and repository operations in isolation, with dependencies mocked to ensure predictable and repeatable outcomes. Integration tests exercised module interactions and confirmed correct database behavior against a dedicated test schema. End-to-end tests using Supertest simulated complete HTTP request and response cycles across the critical user workflows, including registration, OTP verification, clinical session creation, encounter submission, and diagnostic result upload. Security testing was conducted using OWASP ZAP alongside manual verification of authentication and authorization controls. Role-based access enforcement was confirmed to correctly reject requests from unauthorized roles on all protected endpoints, and JWT validation was verified to reject expired, malformed, and tampered tokens. Admission control behavior, including rate limiting on authentication and OTP endpoints, was validated under simulated concurrent request loads to confirm the effectiveness of the traffic governance layer. Performance testing conducted with k6 demonstrated that critical endpoints, including login, medical record retrieval, and permission token generation, maintained acceptable response times under realistic concurrent user scenarios. Redis-backed rate limit counters and session blacklists were confirmed to reduce database load on high-frequency operations, validating the caching strategy employed in the system's architecture.

Summary Observations

The prototype confirmed the technical feasibility of the Sijill architecture. The modular monolith structure successfully enforced separation of concerns across domains without introducing the operational overhead of a fully distributed microservices deployment. The patient-controlled permission token mechanism proved implementable within standard JWT infrastructure, providing a practical and fully auditable consent model without requiring specialized blockchain or attribute-based encryption technologies. The graceful degradation of the AI health snapshot feature demonstrated that third-party AI integrations can be incorporated without making the core system dependent on their availability. Collectively, the implemented system constitutes a functional, documented, and tested proof-of-concept for a patient-centric, interoperable Electronic Health Record platform, directly aligned with the objectives defined in Section 1.4.

5. Conclusion & Future Work

5.1 Conclusion

The Sijill project set out to address a critical and consequential problem in the Egyptian healthcare landscape: the fragmentation of patient medical data across disconnected institutional silos, which leads to diagnostic errors, redundant procedures, clinical inefficiency, and patient disempowerment. The core thesis underlying this work is that these systemic failures are not inevitable but are, rather, the product of a missing infrastructure layer; one that connects patients, healthcare providers, diagnostic services, and administrative governance within a secure, unified, and patient-controlled digital health platform.

This graduation project has demonstrated that such an infrastructure layer is both architecturally sound and technically achievable. Through a systematic requirements analysis, a principled system design grounded in healthcare-grade security and interoperability standards, and a full prototype implementation, the Sijill system has realized the primary objective stated in Section 1.4: the design, implementation, and validation of a secure, scalable, and interoperable Unified Electronic Health Record system.

The implemented system delivers on each of its specific technical objectives. A centralized health data repository was constructed, encoding clinical diagnoses using the ICD-11 standard and structuring all data within a PostgreSQL relational schema designed for integrity and traceability. A privacy-centric access control framework was realized through the patient-issued permission token mechanism, which operationalizes patient consent as a first-class architectural component rather than a policy afterthought. An intuitive patient empowerment portal was delivered through the mobile application, giving patients unified access to their medical identity, clinical history, health journal, and reminder management. Efficient clinical workflow tooling was built for healthcare providers, enabling structured encounter documentation with ICD-11 code lookup, medical order issuance, and automated patient notification. Upload-only diagnostic portals enforced the principle of least privilege for laboratories and imaging centers, ensuring that these entities can contribute to the patient record without gaining visibility into it. Administrative verification and governance workflows were implemented, tested, and validated against their defined requirements.

Beyond its individual features, Sijill contributes a coherent architectural pattern for a national health data platform that is patient-controlled rather than institution-controlled. The patient-issued, time-limited, hashed permission token mechanism provides a practical, low complexity, and fully auditable alternative to more theoretically sophisticated consent models that have historically struggled with real-world clinical adoption. This design choice reflects a deliberate priority: pragmatic deploy ability over architectural complexity.

Sijill is submitted as an academic prototype and proof of concept. Its full realization as operational national infrastructure remains, as stated in the Governance chapter, exclusively within the authority of the competent governmental bodies. However, the contribution of this project lies in demonstrating that the technical foundation for such a system is well-defined, achievable, and ready to be built upon.

5.2 Future Work

The current prototype establishes a functional and validated core, and several meaningful extensions have been identified for future development phases.

QR Code-Based Permission Tokens. The current permission token mechanism requires the patient to generate and verbally communicate a 6-digit code to the healthcare provider or diagnostic service in real time. While functional and secure, this model implicitly assumes that the patient is physically present and capable of operating their mobile device at the point of care. A significant planned extension is a QR code-based token generation flow, in which the patient generates a permission token that is encoded into a scannable QR code displayable on the mobile application. A healthcare provider or laboratory would then scan the code using a dedicated interface within their respective portal, eliminating the need for the patient to manually relay a numeric code. Beyond improving usability in standard interactions, this mechanism is particularly important in scenarios where the patient is incapacitated, elderly, or otherwise unable to interact with their device, ensuring that the patient-controlled consent model remains operational in high stakes clinical situations without compromising its security guarantees.

AI-Powered Patient Health Assistant. The current implementation integrates the Gemini API in a reactive and bounded capacity, generating a one-time health snapshot in response to a specific journal entry submission. A planned major extension is a persistent, conversational AI health assistant embedded within the patient mobile application. This assistant would operate with full awareness of the patient's medical context, including active diagnoses, current medications, allergies, and recent health journal entries, enabling it to answer patient questions about their conditions, explain medical terminology encountered in their records, highlight potential medication interactions for discussion with their provider, and proactively surface reminders approaching medication end dates or overdue follow-up appointments. The assistant would be designed with explicit and transparent scope boundaries, positioning itself clearly as an informational aid and not a diagnostic or prescribing tool, ensuring that its integration strengthens rather than blurs the boundary between patient self-management and clinical decision-making.

Several further enhancements are anticipated in longer-term development phases. Integration with the FHIR (Fast Healthcare Interoperability Resources) standard would enable Sijill to interoperate with other compliant health information systems, substantially broadening the platform's integration surface and its potential reach within an increasingly connected global health IT landscape. A dedicated research portal for authorized public health personnel to perform aggregate, anonymized queries over the platform's data would enable the population-level analytics described in Section 1.4, fulfilling the vision of Sijill as a resource for evidence-based public health planning. Integration with wearable health monitoring devices for continuous data ingestion would substantially enrich the patient's longitudinal health profile and enhance the contextual relevance of the AI health assistant. Finally, comprehensive penetration testing and a formal security audit conducted by an independent party would be a prerequisite before any deployment into a real clinical environment, ensuring that the system's security posture meets the standards demanded by the sensitivity of the data it handles

6. References & Appendices

6.1 References

- [1] Evans, R. S. (2016). Electronic Health Records: Then, Now, and in the Future. Yearbook of Medical Informatics. <https://www.thieme-connect.de/products/ejournals/abstract/10.15265/IYS2016-s006>
- [2] Kruse, C. S., Stein, A., Thomas, H., & Kaur, H. (2018). The Use of Electronic Health Records to Support Population Health: A Systematic Review of the Literature. Journal of Medical Systems. <https://link.springer.com/article/10.1007/s10916-018-1075-6>
- [3] The Ministry of Planning and Economic Development. (2021). Egypt Vision 2030: Sustainable Development Strategy. <https://mped.gov.eg/DynamicPage?id=115&lang=ar&%D8%B1%D8%A4%D9%8A%D8%A9-%D9%85%D8%B5%D8%B1-2030--->
- [4] Alshamrani, A., Benslimane, D., & Benbernou, S. (2025). From Data Silos to Health Records Without Borders: A Systematic Survey on Patient-Centered Data Interoperability. Information. <https://www.mdpi.com/2078-2489/16/2/106>
- [5] Makary, M. A., & Daniel, M. (2016). Medical error—the third leading cause of death in the US. <https://www.bmj.com/content/353/bmj.i2139>
- [6] ICD-11(International Classification of Diseases 11th Revision). The global standard for diagnostic health information. <https://icd.who.int/en/>
- [7] SNOMED CT (Is the most comprehensive, multilingual clinical healthcare terminology in the world) <https://www.snomed.org/what-is-snomed-ct>
- [8] Institute of Medicine (IOM). (2012). Health IT and Patient Safety: Building Safer Systems for Better Care. Washington, DC: National Academies Press. <https://www.ncbi.nlm.nih.gov/books/NBK189661/>

- [9] Delbanco, T., et al. (2012). “Inviting patients to read their doctors’ notes: a quasi-experimental study.” *Annals of Internal Medicine*. <https://www.acpjournals.org/doi/10.7326/0003-4819-157-7-201210020-00002>
- [10] Institute of Medicine (IOM). (2012). *For the Public’s Health: The Role of Measurement in Action and Accountability*. Washington, DC: National Academies Press.
<https://www.nationalacademies.org/projects/DBASSE-CEGIS-10-01>
- [11] Institute of Medicine (IOM). *Health IT and Patient Safety: Building Safer Systems for Better Care*. National Academies Press, 2012. <https://www.nationalacademies.org/publications/13269>
- [12] Blumenthal, D., & Tavenner, M. (2010). The “meaningful use” regulation for electronic health records. *New England Journal of Medicine*. <https://www.nejm.org/doi/abs/10.1056/NEJMp1006114>
- [13] Regional health information exchanges formed under U.S. policy after the HITECH Act demonstrate both feasibility of data sharing and complex governance and consent challenges
<https://healthit.gov/health-it-basics/>
- [14] Estonia’s integrated national EHR, tied to state-issued digital ID, provides a centralized repository accessible to both clinicians and patients.
<https://e-estonia.com/solutions/e-health-2/ehealth-records/>
- [15] Saudi Arabia’s National Platform for Health and Insurance Exchange Services (NPHIES), initiated under national policy, functions as a centralized health information exchange connecting providers, insurers, and third-party administrators.
<https://www.solver-erp.com/blog/exploringnphies-saudi-arabia-health-information-exchange>
- [16] Mandel, J. C., Kreda, D. A., Mandl, K. D., Kohane, I. S., & Ramoni, R. B. (2016). SMART on FHIR: a standards-based, interoperable apps platform for electronic health records. *Journal of the American Medical Informatics Association*.
<https://academic.oup.com/jamia/article/23/5/899/2379865>
- [17] Mamlin, B., Biondich, P., Wolfe, B., Fraser, H., & Allen, C. (2006). OpenMRS: A flexible, open-source medical record system platform to build EMR systems in developing countries. *Proceedings of AMIA Annual Symposium*. <https://pmc.ncbi.nlm.nih.gov/articles/PMC1839265/>
- [18] Adler-Milstein, J., & Jha, A. K. (2017). HITECH Act drove large gains in hospital electronic health record adoption. *Health Affairs*. <https://www.healthaffairs.org/doi/10.1377/hlthaff.2016.1651>

[19] Azaria, A., Ekblaw, A., Vieira, T., & Lippman, A. (2016). MedRec: Using blockchain for medical data access and permission management. Proceedings of the 2nd International Conference on Open and Big Data (OBD). <https://ieeexplore.ieee.org/document/7573685>